

- Internally run or hosted at a third-party service provider and where, if applicable.
- Criticality based on the software assessment (e.g., line of business use, interconnectivity, and recovery priority).
- Data classification based on data type (e.g., sensitive customer or entity information).
- Physical or virtual location.

III.B.2 IT Asset End-of-Life

With respect to technology, EOL is a time frame usually defined by a technology vendor to describe when an asset has reached the end of its useful life cycle or when the vendor will no longer support the asset or continue to sell or license it. All technology, including hardware, software, and assets in the cloud, has an asset life cycle. NIST states that an asset's typical life cycle²⁴ includes enrollment, operation, and EOL phases. Each IT asset should be captured in the entity's ITAM inventory, tracked throughout its operational life to monitor for changes (e.g., vendor announcements regarding support or changes in functionality, reliability, or processing speed) in the asset or the changing needs of the entity, and prepared for physical removal at the end of its useful life. Management should implement policies, standards, and procedures to identify assets and their EOL time frames, to track assets' EOLs, and to replace, or upgrade, the asset. Failure to maintain effective identification, tracking, and replacement processes could have operational or security implications (e.g., unavailable or unapplied security updates [patches] that make technology vulnerable to disruption).

EOL for hardware (e.g., servers, routers, and cables) refers to the end of its useful life when the hardware is no longer capable of supporting the entity's strategic objectives. Hardware EOL may be due to issues such as wear and tear, capacity or speed issues, or obsolescence of hardware components. Alternatively, software EOL refers to the time frame when a software development company no longer provides automatic fixes, updates, or software support for the product (e.g., OS or application software). Management should address EOL in contract provisions with its third-party service providers. For more information on contract provisions, refer to the *IT Handbook's* "[Outsourcing Technology Services](#)" booklet.

With respect to existing technology, effective EOL management should include the following:

- Adding assets to the information and technology inventories and tracking changes made to assets.
- Conducting risk assessments to help determine the EOLs of existing assets.
- Reviewing EOL time frames for existing assets to determine accuracy and relevance.
- Developing replacement plans for assets nearing obsolescence.
- Establishing procedures for the secure destruction or data wiping of hardware (e.g., hard drives; copy machines; servers, desktops, and laptops; or mobile devices) and software (e.g., databases) to prevent the inadvertent disclosure of sensitive information.

For new technology assets, effective EOL management should include the following:

²⁴ Refer to NIST Special Publication (SP) 1800-5, [IT Asset Management](#).

- Incorporating EOL considerations in strategic planning.
- Planning for obsolescence during initial project stages (e.g., during requests for proposals or proofs of concept).
- Registering and tracking assets in the information and technology asset inventories, including available EOL information.
- Developing plans for maintaining operational viability and security of IT assets beyond EOL, if necessary.

III.B.3 Shadow IT

Shadow IT refers to IT devices, software, or services operating within the entity's environment without the knowledge, approval, or control of IT management. Shadow IT can also be identified within a third-party service provider's environment. Unapproved devices, software, or services should not be running at the entity, but they could be placed there by the following:

- Business units to support their specific needs in contravention to the enterprise's needs.
- Third-party service providers to support services provided to the entity or to collect data for the service providers.
- Individuals (internal or external) for convenience to allow them to use entity resources (e.g., wireless network) or for malicious purposes (e.g., to steal data or processing power).
- Incomplete decommissioning process for legacy systems (e.g., business unit systems that were never decommissioned because of software compatibility limitations).

Failure to address the risks of shadow IT may lead to an unknown attack vector due to management's lack of awareness of unapproved devices, software, or services. Therefore, management should understand and communicate the following risks of shadow IT to the entity's personnel:

- Security weaknesses, data breaches, or data loss from using unapproved devices, software, or services.
- Inability to maintain or update (e.g., apply patches to) unknown devices or software resulting in vulnerable devices or software.
- Costs related to identifying, diagnosing, and mitigating security issues.
- Inability to back up and recover unknown devices or software.
- Unintentionally performing automatic backups of unapproved and possibly infected devices or software leading to the spread of malware.
- Penalties for using software or services without a license.
- Legal risks related to data use or data ownership (e.g., data residing on devices outside of the ownership or control of the entity).
- Potential nullification of cyber insurance.

Management should establish IT governance practices and security controls along with consistent policies, standards, and procedures to mitigate risks of shadow IT. Security awareness training should include the risks of shadow IT and the rationale for preventing its use. Such

training may deter deployment of shadow IT, encourage personnel to notify management of its use, and inform personnel of notification procedures (e.g., how and when to notify).

Identification of shadow IT on an entity's network or systems often occurs through regular review of the network's assets, comparing the results of the review to approved assets on the inventories and diagrams. Using IT detection tools may allow management to monitor for and identify shadow IT (e.g., unauthorized IoT devices or rogue Wi-Fi connections). When connected to the cloud, software or hardware tools (e.g., cloud access security brokers) can be used to discover unknown applications. In addition, management should employ appropriate data protection and data loss prevention tools to minimize the potential for exfiltration or misuse of sensitive customer and entity information.

The identification of shadow IT does not eliminate it. Shadow IT remains until management appropriately addresses it. While shadow IT should be addressed in a timely manner, there is a risk that removing shadow IT could negatively affect a department process. The entity's reputation, product and service delivery, and revenue stream could be affected if shadow IT is removed without an appropriate plan. Management should perform the following when determining appropriate methods to address shadow IT:

- Identify security risks associated with shadow IT in use and determine whether there is malicious intent.
- Identify the reason for use (e.g., compatibility issues or preference for specific device type).
- Determine the clients or processes shadow IT may be supporting.
- Verify interconnectivity with third-party service providers and integration with other entity software.
- Determine the appropriate disposition of shadow IT (e.g., remove or transition to entity-managed infrastructure and add to the ITAM process).
- Review policies, processes, and tools to understand any gaps that may allow shadow IT to occur.

Without appropriate identification of shadow IT, independent reviews (e.g., penetration tests, vulnerability assessments, or audits) may not be comprehensive. While audit processes typically do not identify shadow IT, internal audit should evaluate management's processes to monitor, identify, and remove unapproved devices, software, or services.

III.C IT and Business Environment Representations

Common types of documentation maintained to represent the entity's IT and business environments are network diagrams, data flow diagrams, business process flow diagrams, and business process narratives. Management should document and maintain accurate representations of the current IT and business environments and should employ processes to update representations after the implementation of significant changes. Representations may assist management by identifying the following:

- Physical and virtual technology assets (e.g., hardware and software), including locations, version and model numbers, and whether the assets are still supported.

- Information (digital and physical, as appropriate) assets (e.g., location and flow of sensitive customer information and data storage locations), including interdependencies of assets, data classification, owner designation, and environment details (e.g., production, test, or development).
- Hardware and connections for network maintenance, troubleshooting, and recovery from disruptions.
- Interconnectivity and process flows between and among the following:
 - Lines of business.
 - Entity and external parties (e.g., third-party service providers and customers).
 - Network access points (e.g., VPN connections).
 - Other devices.
- Points of internal or external connectivity that may need protection or additional controls that may be appropriate.
- Locations of sensitive data at rest and security points for data in transit.
- Potential for expansion (e.g., new technologies), reconfiguration, or removal of technology assets.
- Opportunities for business process improvements (e.g., incompatible business line process flows).

While various representations may be used for different purposes, management should coordinate the development of representations among stakeholders. This coordination allows management to obtain a holistic view of the entity's IT environment and understand how it supports business processes. The diagrams and narratives should be aligned with each other and across lines of business. For example, if the business flow diagram refers to a particular function, or application, other diagrams and narratives should use similar naming conventions to refer to that function for reference purposes.

Management should periodically review documented diagrams and narratives to verify the accuracy of the representations of the IT and business environments. Inaccurate information could result in incorrect decisions, which could lead to security vulnerabilities, maintenance issues, or recovery delays. Management should provide for the resilience of this documentation by maintaining current and accurate backups.

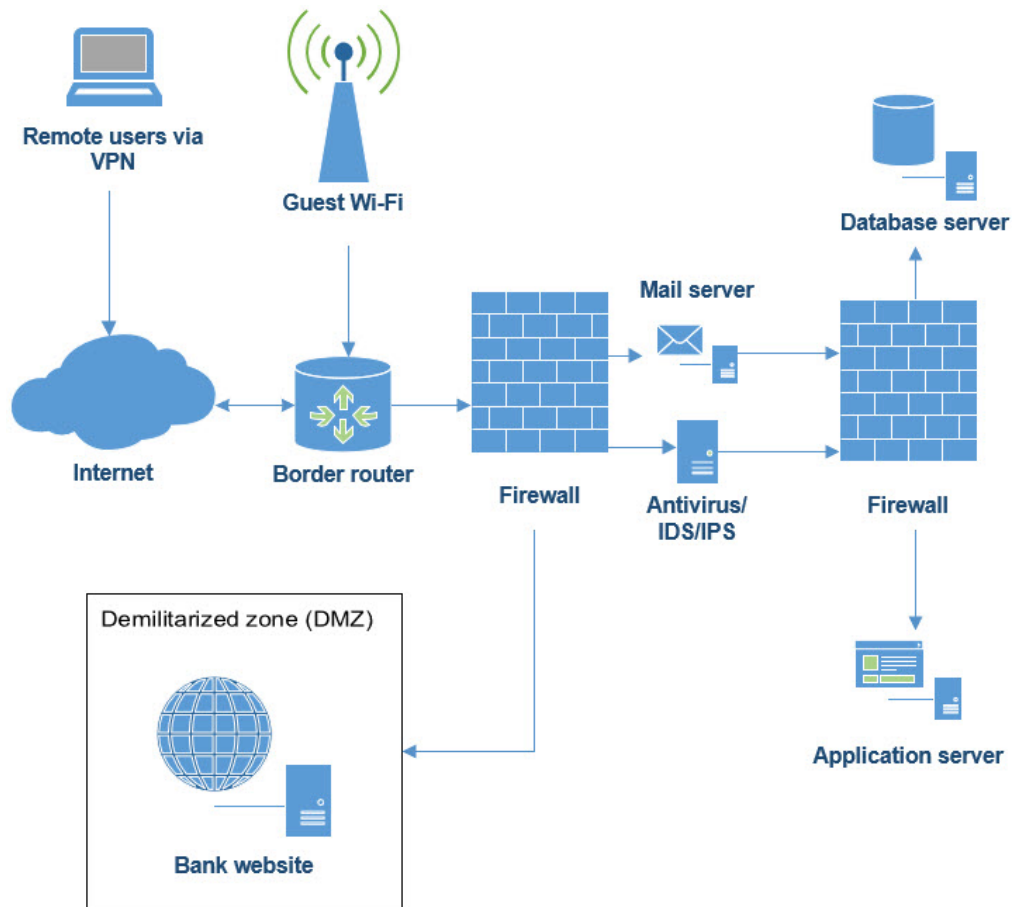
Management should appropriately restrict access and editing privileges to the representations due to the confidential or sensitive information they contain (e.g., IP addresses, location, or interconnectivity of network elements). Management should consider developing versions of the diagrams or narratives with only the information needed for entity and third-party service provider personnel to perform their duties.

For larger or more complex entities, manual documentation and monitoring processes may not be effective at identifying all pertinent information. Therefore, automated tools may be used to document and assist in the management of the IT and business environment.

III.C.1 Network Diagrams

A network diagram (also called a network map or network topology) is a visual representation of nodes and connections in a computer network. Figure 2 is an example of a network diagram. An entity's network diagram may include the following:

- Hardware (e.g., critical systems, routers and switches, and storage devices) and virtual components (e.g., virtual servers and cloud infrastructure).
- Internal and external connections (e.g., internet access, cloud access, remote access, and third-party access).
- Network segments and associated trust level (e.g., trusted, semi-trusted, untrusted, or restricted), including boundary protections.
- Bandwidth of connectivity within and between network segments.
- Infrastructure used to support specific business units.
- Geographical locations of infrastructure.
- Connectivity (e.g., fiber optic, multiprotocol label switching (also known as MPLS), VPN, dial-up, and wireless).
- Security elements (e.g., firewalls and IDS/IPS).
- IP addresses of specific infrastructure elements.
- Connection points for third-party service providers and customers.
- Encrypted or other secure communication channels.

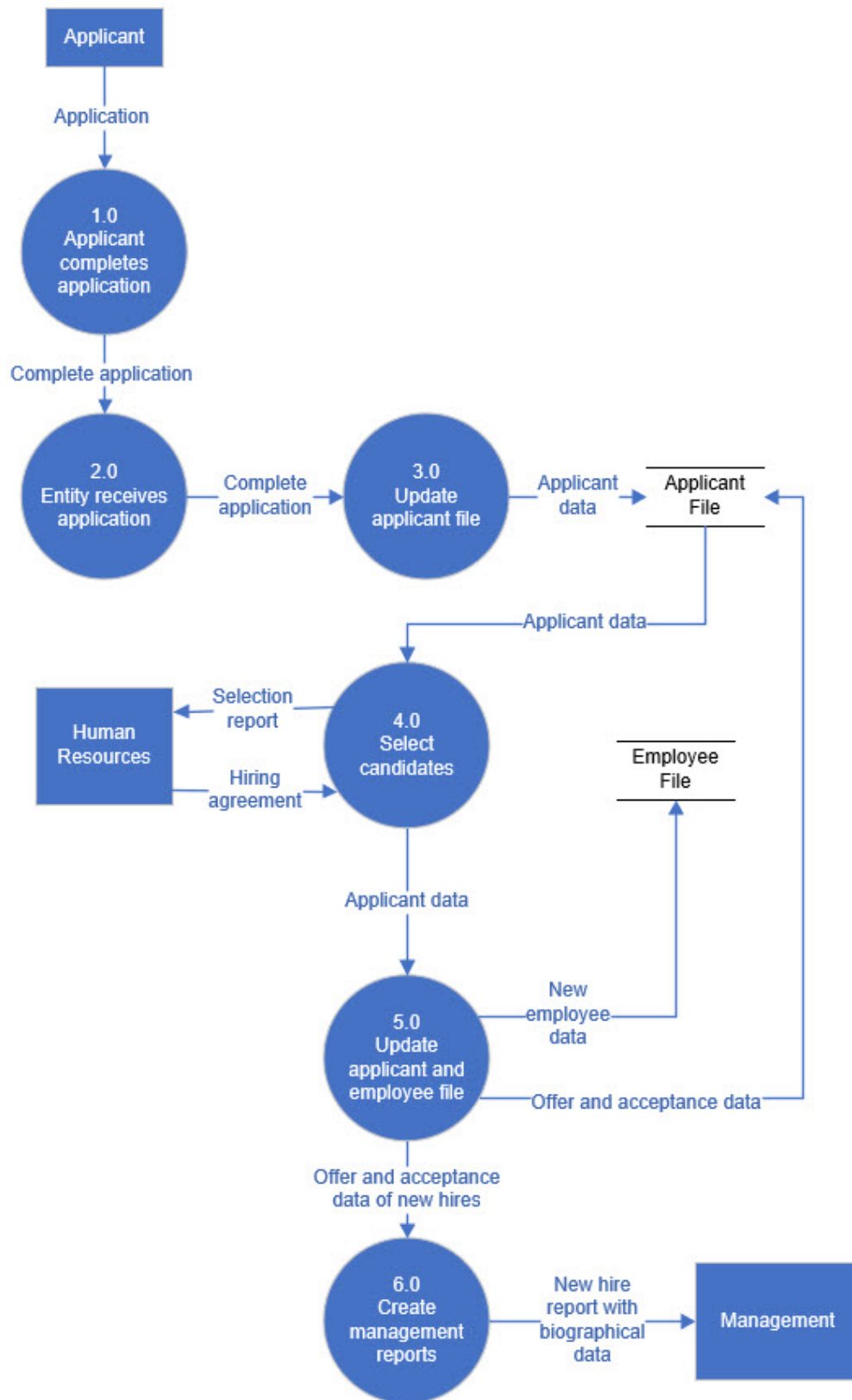
Figure 2. Example of a Network Diagram

Note: Figure 2 is for illustrative purposes only and shows components a network diagram may contain.

III.C.2 Data Flow Diagrams

A data flow diagram is a graphical representation of the flow of data internally through the entity's network(s), business units, products, and software, and to third parties, as applicable. (Refer to figure 3.) Data flow diagrams and network diagrams may include similar information (e.g., critical hardware) but have different purposes. Data flow diagrams show how the entity's data flows between critical hardware on the network, not just where a piece of hardware resides.

Figure 3. Example of a Data Flow Diagram



Note: Figure 3 is for illustrative purposes and does not show every step in the process.

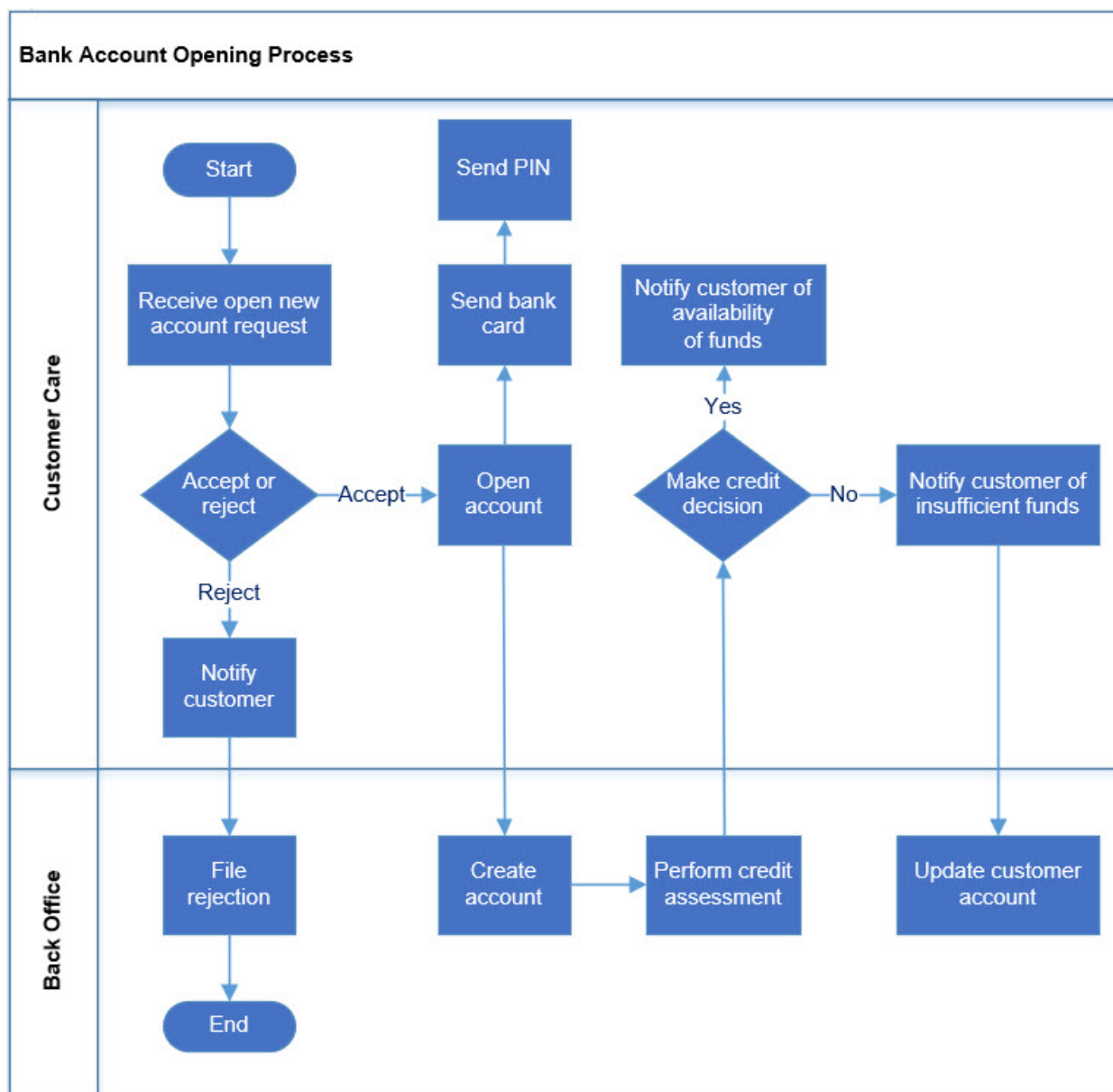
In smaller or less complex IT environments, data flow diagrams and network diagrams may be combined. In larger or more complex IT environments, the entity generally has multiple data flow diagrams and network diagrams broken out in a variety of ways (e.g., lines of business, geographic locations, network segments, and business functions). Data flow diagrams may include the following:

- Storage locations of data (i.e., data at rest), especially sensitive data, and where data flow between equipment and systems (i.e., data in transit).
- Data sharing between applications.
- References to network diagrams for details of internal and external connectivity.
- Specific operational or business processes and any single points of failure.
- Data flow within the entity (e.g., operational or business process interaction and interdependencies) and between the entity and its third-party service providers.

III.C.3 Business Process Diagrams and Narratives

Business process diagrams depict the relationships between an entity's business processes and control points, including interactions and interdependencies. The diagrams illustrate processes, functions, and decision points for a business activity, such as those depicted in figure 4. The diagrams often depict the handoff between departments that have a role in carrying out different parts of the business activity.

Figure 4. Example of Process Flow Diagram



Business process narratives, on the other hand, describe the entity’s business processes and related control points, often to support control reporting, such as for SOX or SOC reports. Business process narratives often align with and help provide additional information about business process diagrams and control objectives and may be useful for understanding how an entity’s business units function.

III.D Managing Change in AIO

An entity’s IT environment and its products and services, whether internally or externally provided, should be adaptable to change. Management generally makes changes to meet strategic goals and objectives (e.g., adding new products or services, growing the entity’s business,

providing integration and centralization of functionality, expanding to new geographic areas, or expanding operational capabilities) or to deliver financial, performance, or security improvements. Changes may be accomplished by implementing new technology (e.g., systems or software) to support new or changing products and services. Once management initiates changes, it relies on involvement from architecture for design, infrastructure to build, and operations to deploy the changes needed to meet the strategic goals. Depending on the type, complexity, and impact of the change, stakeholders across the entity should have input into the change process.

For complex changes (e.g., core conversions, migrations to cloud-based environments, or implementing a system to support a new product), formal planning and management oversight processes are warranted. For routine changes (e.g., implementation of patches), management may follow a less extensive process. Regardless of the type, management should ensure that changes to any IT system or service are supported by an orderly, adaptable, documented, and measurable process. Such a process can minimize risk, maintain the integrity and security of the entity's IT infrastructure, maintain or enhance the value to the business, and maintain uninterrupted delivery of the service. For more information on implementing technology changes, refer to the *IT Handbook's* "[Development and Acquisition](#)" booklet.

III.D.1 Change Management

Change management is the continuous process of maintaining the integrity of hardware, software, firmware, and documentation, and controlling and approving changes (e.g., addition, modification, or elimination) to information or technology assets or related infrastructure. Change management is an operational process that involves the implementation and management of changes to meet the strategic goals of the entity. Some changes to the IT environment may occur within the entity's infrastructure (e.g., hardware, software, and telecommunications), while others may involve third-party service providers (e.g., cloud or managed security service providers). While some change management activities may involve longer-term strategic planning and IT architecture, other changes, such as remediating vulnerabilities or responding to malicious events, may require more rapid action.

The entity's policies, standards, and procedures should address change management, including each step of the change process. Policies, standards, and procedures should categorize changes by severity, specify corresponding approval processes, and identify responsible staff, applicable stakeholder working groups, or entity committees. Management should identify metrics (e.g., implementation time, success rates, and the number of planned versus unplanned changes) to track the efficiency and success of the change management process.

An entity's change management process should ensure that changes are implemented with the goal of preserving the IT environment's confidentiality, integrity, and availability. Management should incorporate appropriate segregation of duties and monitoring throughout the change management process as outlined in the *IT Handbook's* "[Information Security](#)" and "[Development and Acquisition](#)" booklets. Ideally, the change management process consists of the following: